

Jeremiah Grossman

Venture capitalist (Grossman Ventures <https://grossman.vc>), Internet protector and industry creator. Founded WhiteHat Security & Bit Discovery. BJJ Black Belt.

TUESDAY, JANUARY 12, 2010

Top Ten Web Hacking Techniques of 2009 (Official)

Every year the Web security community produces dozens of new hacking techniques documented in white papers, blog posts, magazine articles, mailing list emails, etc. Not to be confused with individual vulnerability instances brandishing CVE numbers, nor intrusions / incidents, but actual new methods of Web attack. Some techniques target websites, others Web browsers, and the rest somewhere in between. Historically much of this research would unfortunately end up in obscure corners of the Web and become long forgotten. Now it its fourth year the Top Ten Web Hacking Techniques list provides a centralized repository for this knowledge and recognize researchers contributing to the advancement of our industry. 2009 produced ~80 new attack techniques (see below).

The diversity, volume, and innovation of the research was impressive. Competition was as fierce as ever and the judges had their work cut out. Rich Mogull, Dinis Cruz, Chris Hoff, HD Moore, Billy Rios, Dan Kaminsky, Romain Gaucher, Steven Christey, Jeff Forristal, and Michal Zalewski were tasked with ranking the field based upon novelty, impact, and overall pervasiveness. For any researcher simply the act of creating something unique enough to appear on the list is itself an achievement. Today the polls are close, votes are in, and the top ten list has been finalized. Researchers making the cut can expect to receive praise amongst their peers and take their place amongst those from previous years ([2006](#), [2007](#), [2008](#)).

Top honors go to Alexander Sotirov, Marc Stevens, Jacob Appelbaum, Arjen Lenstra, David Molnar, Dag Arne Osvik, Benne de Weger for their work on "Creating a rogue CA certificate." The judges were convinced by no small margin that this entry stood head and shoulders above the rest. The team will be awarded a free pass to attend the [BlackHat USA Briefings 2010!](#) (generously sponsored by Black Hat)

Top Ten Web Hacking Techniques of 2009!

1. Creating a rogue CA certificate

Alexander Sotirov, Marc Stevens, Jacob Appelbaum, Arjen Lenstra, David Molnar, Dag Arne Osvik, Benne de Weger

2. HTTP Parameter Pollution (HPP)

Luca Carettoni, Stefano diPaola

3. Flickr's API Signature Forgery Vulnerability (MD5 extension attack)

Thai Duong and Juliano Rizzo

4. Cross-domain search timing



BIO

Jeremiah Grossman brings 20+ years of experience in Computer Security and has become one of the most recognizable and world-renowned cybersecurity experts in the industry, coining several of the original hacking terms commonly used around the world today. Early in his career, Jeremiah was known as "The Hacker Yahoo" which led to his role as the company's Information Security Officer. Jeremiah founded WhiteHat Security (now Synopsis), and served as Chief of Security Strategy for SentinelOne which was the highest-valued cybersecurity IPO in history. Most recently, Jeremiah was the founder & CEO of Bit Discovery, which was acquired by Tenable in 2022. He also serves as a company advisor and board member to several tech startups. In his spare time, Jeremiah does Brazilian Jiu-Jitsu and is passionate about classic cars. He recently opened Toybox, a luxury car club in Boise, Idaho.

LINKS

[Jeremiah Grossman](#)

[Twitter](#)

[Facebook](#)

[LinkedIn](#)

[Grossman Ventures](#)

SUBSCRIBE

Posts

Comments

5. Slowloris HTTP DoS

Robert Hansen, (additional credit for earlier discovery to [Adrian Ilarion Ciobanu](#) & Ivan Ristic - "Programming Model Attacks" section of [Apache Security](#) for describing the attack, but did not produce a tool)

6. Microsoft IIS o-Day Vulnerability Parsing Files (semi-colon bug)

Soroush Dalili

7. Exploiting unexploitable XSS

Stephen Sclafani

8. Our Favorite XSS Filters and how to Attack them

Eduardo Vela ([sirdarckcat](#)), David Lindsay ([thornmaker](#))

9. RFC1918 Caching Security Issues

Robert Hansen

10. DNS Rebinding (3-part series [Persistent Cookies](#), [Scraping & Spamming](#), and [Session Fixation](#))

Robert Hansen

Congratulations to all!

Coming up at [IT-Defense](#) (Feb. 3 - 5) and [RSA USA 2010](#) (Mar. 1 - 5) it will be my great honor to introduce each of the top ten during my "2010: A Web Hacking Odyssey" presentations. Each technique will be described in technical detail for how they work, what they can do, who they affect, and how best to defend against them. The opportunity provides a chance to get a closer look at the new attacks that could be used against us in the future.

The Complete List

1. [Persistent Cookies and DNS Rebinding Redux](#)
2. [iPhone SSL Warning and Safari Phishing](#)
3. [RFC 1918 Blues](#)
4. [Slowloris HTTP DoS](#)
5. [CSRF And Ignoring Basic/Digest Auth](#)
6. [Hash Information Disclosure Via Collisions - The Hard Way](#)
7. [Socket Capable Browser Plugins Result In Transparent Proxy Abuse](#)
8. [XMLHttpRequest "Ping" Sweeping in Firefox 3.5+](#)
9. [Session Fixation Via DNS Rebinding](#)
10. [Quickly Firefox DoS](#)
11. [DNS Rebinding for Credential Brute Force](#)
12. [SMBEnum](#)
13. [DNS Rebinding for Scraping and Spamming](#)
14. [SMB Decloaking](#)
15. [De-cloaking in IE7.0 Via Windows Variables](#)
16. [itms Decloaking](#)
17. [Flash Origin Policy Issues](#)
18. [Cross-subdomain Cookie Attacks](#)
19. [HTTP Parameter Pollution \(HPP\)](#)
20. [How to use Google Analytics to DoS a client from some website.](#)
21. [Our Favorite XSS Filters and how to Attack them](#)
22. [Location based XSS attacks](#)
23. [PHPIDS bypass](#)

24. I know what your friends did last summer
25. Detecting IE in 12 bytes
26. Detecting browsers javascript hacks
27. Inline UTF-7 E4X javascript hijacking
28. HTML5 XSS
29. Opera XSS vectors
30. New PHPIDS vector
31. Bypassing CSP for fun, no profit
32. Twitter misidentifying context
33. Ping pong obfuscation
34. HTML5 new XSS vectors
35. About CSS Attacks
36. Web pages Detecting Virtualized Browsers and other tricks
37. Results, Unicode Left/Right Pointing Double Angel Quotation Mark
38. Detecting Private Browsing Mode
39. Cross-domain search timing
40. Bonus Safari XXE (only affecting Safari 4 Beta)
41. Apple's Safari 4 also fixes cross-domain XML theft
42. Apple's Safari 4 fixes local file theft attack
43. A more plausible E4X attack
44. A brief description of how to become a CA
45. Creating a rogue CA certificate
46. Browser scheme/slash quirks
47. Cross-protocol XSS with non-standard service ports
48. Forget sidejacking, clickjacking, and carjacking: enter "Formjacking"
49. MD5 extension attack
50. Attack - PDF Silent HTTP Form Repurposing Attacks
51. XSS Relocation Attacks through Word Hyperlinking
52. Hacking CSRF Tokens using CSS History Hack
53. Hijacking Opera's Native Page using malicious RSS payloads
54. Millions of PDF invisibly embedded with your internal disk paths
55. Exploiting IE8 UTF-7 XSS Vulnerability using Local Redirection
56. Pwning Opera Unite with Inferno's Eleven
57. Using Blended Browser Threats involving Chrome to steal files on your computer
58. Bypassing OWASP ESAPI XSS Protection inside Javascript
59. Hijacking Safari 4 Top Sites with Phish Bombs
60. Yahoo Babelfish - Possible Frame Injection Attack - Design Stringency
61. Gmail - Google Docs Cookie Hijacking through PDF Repurposing & PDF
62. IE8 Link Spoofing - Broken Status Bar Integrity
63. Blind SQL Injection: Inference through Underflow exception
64. Exploiting Unexploitable XSS
65. Clickjacking & OAuth
66. Google Translate - Google User Content - File Uploading Cross - XSS and Design Stringency - A Talk
67. Active Man in the Middle Attacks
68. Cross-Site Identification (XSid)
69. Microsoft IIS with Metasploit evil.asp;.jpg
70. MSWord Scripting Object XSS Payload Execution Bug and Random CLSID Stringency
71. Generic cross-browser cross-domain theft
72. Popup & Focus URL Hijacking
73. Advanced SQL injection to operating system full control (whitepaper)

74. Expanding the control over the operating system from the database
75. HTML+TIME XSS attacks
76. Enumerating logins via Abuse of Functionality vulnerabilities
77. Hellfire for redirectors
78. DoS attacks via Abuse of Functionality vulnerabilities
79. URL Spoofing vulnerability in bots of search engines (#2)
80. URL Hiding - new method of URL Spoofing attacks
81. Exploiting Facebook Application XSS Holes to Make API Requests
82. Unauthorized TinyURL URL Enumeration Vulnerability

Posted by [Jeremiah Grossman](#) at [11:46 AM](#)

9 comments:

thornmaker said...

woot woot

[January 12, 2010 at 3:50 PM](#)

Anonymous said...

wait, rogue cert is 2008! christmas 2008 at CCC and all the research was done in 2008! And moxie attack is real 2009 and is more useful, usable, people can repeat it and is a new bug. The rogue CA cert is well known md5 collisions being abused

debate!

[January 14, 2010 at 8:20 AM](#)

MustLive said...



Nice Top Ten web hacks and the whole list of the hacks!

My congratulation to authors who made the Top Ten.

> Our Favorite XSS Filters and how to Attack them

For somebody they are favorite, for somebody they are not :-). But with no doubts all XSS Filters have holes which can be used to bypass them (and last issue with XSS Filter in IE8 is confirmation to it).

[January 14, 2010 at 10:44 AM](#)

MustLive said...



Anonymous

It's interesting note. Wait for what Jeremiah will say about it.

Your arguments is sufficient, but it was better to said it before Top Ten was selected. I heard about both rogue cert and Moxie's works (at the time that you mentioned).

[January 14, 2010 at 10:50 AM](#)

Pento said...



Thanks a lot for links!

[January 14, 2010 at 11:45 AM](#)

Jeremiah Grossman said...



@anonymous, Rouge Cert was "December 30, 2008", and the news really didn't break until into 2009. Either way it wasn't consider

for our list before, so we included it... and for good reason obviously.

January 15, 2010 at 7:44 AM

80sec said...

The bug wasn't found by Mr.Dalili, the original bug has been published here <http://www.80sec.com/microsoft-internet-information-server-6-isapi-filename-analytic-vulnerabilitie.html> few months ago
im sorry for your childish thoughts

January 19, 2010 at 12:47 PM

cellbloggy said...

Hey.. very nice and useful information. did you mention about PHP injection??? check out my [blog](#) for some more hacking?????

February 5, 2010 at 3:10 AM

El cajon condo said...

Thanks a lot.I have searched many sites.But i got the good idea from your site.Some links are very useful to know something about PHP.. :)

October 26, 2010 at 4:00 AM

[Post a Comment](#)

[Newer Post](#)

[Home](#)

[Older Post](#)

Subscribe to: [Post Comments \(Atom\)](#)

Picture Window theme. Powered by Blogger.

This site uses cookies from Google to deliver its services and to analyse traffic. Your IP address and user agent are shared with Google, together with performance and security metrics, to ensure quality of service, generate usage statistics and to detect and address abuse.

[LEARN MORE](#) [GOT IT](#)